

# Information Security & Data Protection Policy

**Organisation:** AAYAT CONSULTING LTD (Company No. 17061494)

**Registered address:** 130 Holborn Street, Rochdale, United Kingdom, OL11 4QE

**Policy owner:** Director

**Contact:** hello@aayat.co

**Version:** 1.0

**Effective date:** 8 June 2026

**Next review:** 8 June 2027 (reviewed at least annually and after any major change or incident)

This policy governs how Aayat protects information and personal data across its systems, with specific reference to the **Aayat Profitability Portal** ("the Portal") and its integrations with e-commerce platforms including **TikTok Shop**, Amazon and Temu.

## 1. Purpose & Scope

This policy sets out the security and data-protection controls Aayat applies to safeguard the confidentiality, integrity and availability of the data it processes. It applies to:

- All Aayat staff, contractors and anyone with access to Aayat systems.
- All systems used to operate the Portal, including its application hosting, databases, source code, and third-party integrations.
- All data processed by the Portal, including order, settlement/finance and return data obtained from connected shops, and any personal data contained therein.

## 2. Roles & Responsibilities

- The **Director** is accountable for this policy, its enforcement, and its annual review.
- **All staff** must comply with this policy and complete security awareness expectations (device security, credential hygiene, incident reporting).
- The **Director (hello@aayat.co)** acts as the **point of contact for security and data-protection matters**, including breach notification to platforms, sellers and regulators.

## 3. Information Security Policy Statement

Aayat is committed to protecting the data of its customers, the shops it manages, and their end customers. Aayat applies the principle of **least privilege**, **defence in depth**, and **privacy by design**. Security controls are implemented at the application, data, infrastructure and endpoint layers, and are reviewed at least annually.

## 4. Access Control & Least Privilege

- Access to the Portal and its data is **restricted to authorised Aayat staff** on a least-privilege, need-to-know basis.
- The Portal enforces **role-based access control** (admin / team roles) at the application layer.
- The database (Supabase/PostgreSQL) enforces **Row-Level Security (RLS)** so that data access is constrained by role and policy at the data layer.
- Privileged credentials (e.g. database service-role keys) are stored only as server-side secrets and are **never exposed to the browser or client**.
- Access is granted on joining, reviewed periodically, and **revoked promptly** when no longer required.

## 5. Authentication & Credential Management

- **Multi-factor authentication (MFA)** is enabled on all critical administrative accounts, including the source-code repository (GitHub), the hosting platform (Vercel), and the database platform (Supabase).
- Strong, unique passwords are required and managed via a password manager.
- API credentials and OAuth tokens are treated as secrets and stored encrypted (see §7).

## 6. Data Classification

Aayat classifies data as:

- **Restricted / Personal data** — any personal data within order data (e.g. customer name, delivery address, contact details accessible via platform APIs).
- **Confidential** — access tokens, API secrets, cost and financial data.
- **Internal** — aggregated reporting and analytics.

Handling requirements (access, encryption, retention) are applied according to classification, with the strongest controls applied to Restricted and Confidential data.

## 7. Encryption

- **In transit:** all traffic to and from the Portal and all API calls to platform endpoints use **TLS/HTTPS**.
- **At rest:** platform OAuth access/refresh tokens are encrypted at the application layer using **AES-256-GCM** before storage. The underlying database (Supabase) additionally encrypts data at rest.
- Encryption keys are held as server-side secrets, separated from the data they protect, and are rotatable.

## 8. Network & Infrastructure Security

- The Portal is hosted on **managed, isolated cloud infrastructure**: application hosting on **Vercel** and database/storage on **Supabase**.
- These platforms provide network isolation, DDoS protection, traffic monitoring and threat-prevention controls at the infrastructure level.
- Aayat does not operate self-managed production servers; the managed-platform model reduces network-level attack surface.

## 9. Endpoint Security

- Company endpoints run up-to-date operating systems with **anti-virus/anti-malware protection** enabled.
- A **security baseline** is applied: automatic screen lock, full-disk encryption where available, strong device passwords/biometrics, and timely OS/security updates.

## 10. Vulnerability & Patch Management

- Application dependencies are monitored and updated regularly; security patches are applied promptly.
- The managed hosting and database platforms apply infrastructure-level patching automatically.
- Identified vulnerabilities are triaged by severity and remediated on a risk-prioritised basis.

## 11. Logging & Monitoring

- Application and platform logs are retained to support troubleshooting, security monitoring and incident investigation.
- Sync activity and errors are recorded against each connected account.

## 12. Third-Party Service Providers (Sub-processors)

The Portal relies on the following sub-processors. Each is engaged under its own data-processing terms:

| Provider                    | Purpose                                        | Data residency                  |
|-----------------------------|------------------------------------------------|---------------------------------|
| Vercel                      | Application hosting / processing               | See provider terms              |
| Supabase                    | Database, authentication, storage              | <b>EU — Ireland (eu-west-1)</b> |
| TikTok Shop / Amazon / Temu | Source platforms (order, finance, return data) | Per platform                    |
| Resend                      | Transactional email notifications              | See provider terms              |

## 13. Personal Data Protection (UK GDPR / Data Protection Act 2018)

- Aayat processes personal data lawfully, fairly and transparently, limited to what is necessary for profitability reporting for the shops it operates and manages.
- Integrations use **read-only** access to order, finance and return data; the Portal does **not** create, modify or delete data in connected shops.
- Personal data is not sold and is not shared with third parties other than the sub-processors listed above.

## 14. Data Subject Rights

---

Aayat will, within statutory timeframes, assist the relevant shop/seller and platform to **access, correct, provide, or delete** personal data in response to a verified data-subject request.

## 15. Data Retention & Deletion

---

- Data is retained only as long as necessary for reporting purposes.
- On **disconnection** of a shop, stored access/refresh tokens and related credentials are deleted.
- At the **end of the contractual relationship**, all collected customer data in Aayat's possession is deleted.

## 16. Incident Response & Breach Notification

---

- Aayat maintains an incident-response process with defined roles and reporting channels.
- Suspected or identified security incidents must be reported immediately to the Director at hello@aayat.co.
- On confirming a personal-data breach, Aayat will **notify affected sellers and TikTok Shop without undue delay**, and notify the relevant supervisory authority (e.g. the ICO) within **72 hours** where legally required, and affected individuals where the breach poses a high risk.
- Incidents are documented, investigated, and used to improve controls.

## 17. Business Continuity

---

The use of managed cloud platforms provides redundancy and backup. Source code is version-controlled. Recovery procedures are documented and tested periodically.

## 18. Policy Review & Version Control

---

This policy is reviewed at least **annually**, and after any significant change or security incident. Versions and approval dates are recorded below.

| Version | Date        | Author   | Summary        |
|---------|-------------|----------|----------------|
| 1.0     | 8 June 2026 | Director | Initial policy |

---

*This document is an internal company policy for AAYAT CONSULTING LTD. Aayat should have this reviewed by a qualified professional before relying on it for legal/regulatory purposes.*